

Health-Data Bank

USER MANUAL FOR SYSTEM ROLES (USER, HEALTHCARE PROVIDER, RESEARCHER, ADMIN)

Team 1

TABLE OF CONTENTS

1. Introduction.....	4
1.1 Overview of the Health Data Bank System.....	4
1.2 Purpose of Role-Based Access Control (RBAC).....	4
1.3 Document Structure and How to Use This Manual.....	5
1.4 Key Terminology and Definitions.....	5
2. System Overview.....	6
2.1 What is a Role?.....	6
2.2 Why Roles Matter in Health Data Bank.....	6
2.3 The Four Core Roles in the System.....	7
2.4 Role Hierarchy and Permission Structure.....	7
2.5 Authentication and Security Features.....	8
3. User Role (Patient/Regular User).....	9
3.1 Overview and Purpose.....	9
3.2 Getting Started.....	9
3.3 User Dashboard.....	10
3.4 Core Features Available.....	10
3.5 Permissions and Limitations.....	11
3.6 Step-by-Step Tutorials.....	12
4. HCP Role (Healthcare Provider).....	13
4.1 Overview and Purpose.....	13
4.2 Getting Started.....	13
4.3 HCP Dashboard.....	14
4.4 Core Features Available.....	14
4.5 Permissions and Limitations.....	16
4.6 Best Practices.....	17
5. Researcher Role.....	17
5.1 Overview and Purpose.....	17
5.2 Getting Started.....	18
5.3 Researcher Dashboard.....	19
5.4 Core Features Available.....	19
5.5 Permissions and Limitations.....	21
5.6 Compliance and Ethics.....	21
6. Admin Role (Administrator).....	22
6.1 Overview and Purpose.....	22
6.2 Getting Started.....	22
6.3 Admin Dashboard.....	23
6.4 Core Features Available.....	23
6.5 Permissions and Capabilities.....	26
6.6 Sensitive Operations.....	26
6.7 Best Practices for Admins.....	27

7. Role Comparison Matrix.....	27
7.1 Feature Availability by Role.....	27
7.2 Permission Matrix.....	28
7.3 Dashboard Access Summary.....	29
8. Common Workflows and Scenarios.....	30
Scenario 1: A User (Patient) Filing a Health Report.....	30
Scenario 2: An HCP (Healthcare Provider) Reviewing Patient Records.....	31
Scenario 3: A Researcher Accessing Data for a Study.....	32
Scenario 4: An Admin Managing User Accounts and System.....	32
9. Security and Privacy.....	33
9.2 Two-Factor Authentication (2FA).....	34
9.3 Session Management and Timeout.....	34
9.4 Password Requirements and Updates.....	34
9.5 Data Encryption Standards.....	35
9.6 HIPAA Compliance for HCP and Researcher Roles.....	35
9.7 Audit Trail and Logging.....	35
9.8 Account Lockout Procedures.....	36
9.9 Security Best Practices for Each Role.....	36
10. Troubleshooting and FAQs.....	36
• 10.1 Unable to Access Your Dashboard.....	37
10.2 Permission Denied Errors.....	37
10.3 Form Submission Issues.....	37
10.4 Frequently Asked Questions.....	38
11. System Integration and API Access.....	39
11.1 API Token Permissions.....	39
11.2 Role-Based API Access.....	40
12. Support and Additional Resources.....	42
12.1 Getting Help.....	42
13. Glossary of Terms.....	43
14. Appendices.....	44

1. Introduction

1.1 Overview of the Health Data Bank System

The Health Data Bank System is a web-based platform designed to support the secure collection, storage, and analysis of health-related data, particularly for individuals who may not have consistent access to traditional healthcare systems. The platform allows users to submit personal health information through structured forms, track their own health over time, and receive insights based on their data.

In addition to individual users, the system is designed to support other stakeholders, including healthcare providers and researchers. Healthcare providers can review patient data and provide feedback, while researchers can generate anonymized, aggregated reports to study health trends within specific populations. Administrative users are responsible for overseeing the system, managing user roles, and ensuring that all data handling processes meet security and privacy expectations.

Overall, the system aims to balance accessibility and usability with strong data protection practices, ensuring that sensitive health information is handled responsibly.

1.2 Purpose of Role-Based Access Control (RBAC)

Role-Based Access Control (RBAC) is a core component of the Health Data Bank System. It is used to ensure that users can only access the features and data that are appropriate for their role within the system. Instead of giving all users the same level of access, permissions are assigned based on predefined roles such as User, Healthcare Provider, Researcher, and Administrator.

This approach improves both security and usability. From a security perspective, RBAC helps prevent unauthorized access to sensitive health data by restricting what each user can view or modify. For example, researchers are only able to access anonymized data, while healthcare providers can view patient-specific information when appropriate. From a usability perspective, RBAC simplifies the user experience by presenting each role with only the tools and features they need.

By clearly separating responsibilities and permissions, RBAC supports the system's goal of protecting personal health information while still enabling meaningful use of the data.

1.3 Document Structure and How to Use This Manual

This user guide is organized to provide a clear and structured overview of the system and its features. The document begins with a general system overview, followed by detailed sections for each user role. Each role-specific section explains the purpose of the role, the features available, and any limitations or responsibilities associated with it.

Later sections of the guide cover common workflows, security considerations, and troubleshooting. These are intended to help users understand how different parts of the system work together and how to resolve common issues they may encounter.

Users are encouraged to focus on the sections that are most relevant to their role. For example, a regular user may primarily use the User Role section, while an administrator may need to review multiple sections, including system management and security. The workflow scenarios section can also be helpful for understanding how typical tasks are completed within the system.

1.4 Key Terminology and Definitions

To help users better understand the system, several key terms are used throughout this guide:

- **Account:** A unique profile associated with a user of the system. Each account is assigned a role that determines its permissions.
- **Role:** A classification that defines what actions a user can perform within the system (e.g., User, Healthcare Provider, Researcher, Administrator).
- **Form Template:** A predefined structure used to collect health-related information from users. Templates may include various field types such as text inputs, checkboxes, or numeric entries.
- **Form Submission:** A completed instance of a form template submitted by a user, containing their health data.
- **Health Entry:** Individual data points recorded as part of a form submission, often used for tracking trends over time.
- **Cohort:** A group of users selected based on specific criteria (such as age, location, or health metrics) for the purpose of analysis.
- **Aggregated Report:** A summary of data collected from multiple users within a cohort. These reports are anonymized to protect individual identities.
- **Anonymization:** The process of removing or obscuring personally identifiable information so that individuals cannot be identified from the data.

- **Audit Log:** A record of system activities, including user actions such as logins, data access, and administrative changes. This is used for monitoring and accountability.

These terms will appear throughout the guide and are important for understanding how the system operates.

2. System Overview

2.1 What is a Role?

In the Health Data Bank System, a role defines what a user is allowed to see and do within the platform. Instead of giving every user the same access, the system assigns each account a specific role that determines its permissions.

For example, a regular user can submit and view their own health data, while a researcher can analyze anonymized data from multiple users. Each role is designed with a specific purpose in mind, ensuring that users interact with the system in a way that aligns with their responsibilities.

Roles help organize the system by separating functionality, making it easier to manage access and maintain data privacy.

2.2 Why Roles Matter in Health Data Bank

Roles play an important role in maintaining both security and usability within the system. Since the platform handles sensitive health information, it is essential to control who can access certain types of data.

By assigning permissions based on roles:

Sensitive personal data is protected from unauthorized access

Users only see features that are relevant to them

The risk of accidental data misuse is reduced

For instance, researchers are only able to access aggregated and anonymized data, rather than individual records. Similarly, administrators have broader access to manage the system, but their actions are tracked for accountability.

Overall, roles ensure that the system remains secure while still being practical and easy to use for different types of users.

2.3 The Four Core Roles in the System

The Health Data Bank System is built around four main roles, each with a distinct purpose:

- **User (Patient/Regular User)**
This role is intended for individuals who submit their own health data. Users can fill out forms, track their health entries over time, and view summaries of their data.
- **Healthcare Provider (HCP)**
Healthcare providers can access relevant patient data (when permitted) and provide feedback or recommendations. Their role focuses on supporting users with professional insights.
- **Researcher**
Researchers use the system to study health trends across groups of users. They can generate aggregated reports based on selected criteria, but they do not have access to personally identifiable information.
- **Administrator (Admin)**
Administrators manage the overall system. Their responsibilities include managing user accounts, reviewing and approving forms, monitoring system activity, and ensuring that security and compliance measures are followed.

Each role is designed to support a specific type of interaction with the system, while maintaining clear boundaries between different levels of access.

2.4 Role Hierarchy and Permission Structure

The system follows a structured permission model where each role has a defined set of capabilities. While there is no strict “hierarchy” in terms of one role controlling another, some roles have broader access due to their responsibilities.

- **Users** have the most limited access, focused on their own data
- **Healthcare Providers** have access to patient-related data where appropriate
- **Researchers** have access to anonymized, aggregated data across multiple users

- **Administrators** have the highest level of access, allowing them to manage system settings, users, and data workflows

Permissions are enforced by the system at all times. This means that users cannot access features or data outside of what their role allows. These restrictions are automatically applied when a user logs in and interacts with the system.

This structured approach helps maintain consistency and ensures that all actions within the system follow predefined rules.

2.5 Authentication and Security Features

Security is a key aspect of the Health Data Bank System, especially given the sensitive nature of health-related data. The system includes several authentication and security mechanisms to protect user information and maintain data integrity.

Two-Factor Authentication (2FA)

Two-Factor Authentication (2FA) adds an extra layer of security during the login process. In addition to entering a password, users may be required to verify their identity using a second method, such as a one-time code sent to their email or device.

This reduces the risk of unauthorized access, even if a user's password is compromised.

API Token Permissions

The system may provide API access for certain functionalities, particularly for advanced users or integrations. API tokens are used to authenticate these requests.

Each token is associated with specific permissions, ensuring that external access is limited to only what is necessary. Tokens can be managed and revoked if needed, providing additional control over system access.

Session Management

Once a user logs in, the system creates a session that keeps them authenticated while they navigate the platform. To maintain security:

- Sessions may automatically expire after a period of inactivity
- Users are required to log in again after a timeout
- Logging out properly ends the session and prevents further access

Session management helps protect accounts, especially when the system is accessed on shared or public devices.

3. User Role (Patient/Regular User)

3.1 Overview and Purpose

Who is a User?

A User refers to an individual who uses the Health Data Bank System to record and monitor their own health information. This role is typically assigned to patients or regular users who interact with the system on a personal level.

What can a User do?

Users can:

- Submit health-related data through structured forms
- View and track their past submissions over time
- Access summaries and visualizations of their health data
- Manage their personal profile information
- Monitor progress and complete assigned tasks

What can a User NOT do?

Users cannot:

- Access other users' personal data
- View identifiable health data belonging to others
- Generate aggregated reports across multiple users
- Perform administrative actions such as managing accounts or system settings

These restrictions are in place to ensure data privacy and maintain system security.

3.2 Getting Started

Account Creation and Registration

Users can create an account through the registration page by providing basic information such as name, email address, and a secure password. Once registered, they can log in to access their dashboard.

Setting Up Profile

After logging in, users are encouraged to complete their profile. This may include updating personal details such as name or contact information. Keeping profile information accurate helps ensure a smoother experience when using the system.

Security Setup (2FA)

For added security, users may enable Two-Factor Authentication (2FA). This provides an additional layer of protection by requiring a verification step during login, helping to prevent unauthorized access.

3.3 User Dashboard

Accessing the Dashboard (/user/dashboard)

After logging in, users are automatically redirected to their dashboard. This is the main page where they can access all available features.

Dashboard Components and Widgets

The dashboard typically includes:

- A summary of recent health activity
- Quick access to forms and submissions
- Notifications or reminders (if available)
- Visual summaries such as charts or progress indicators

These components are designed to give users a quick overview of their health data and recent activity.

Navigation Menu

The navigation menu (usually located on the side or top of the page) allows users to move between different sections of the system. Common options include:

- Health Summary
- Forms
- Progress Tracking
- Tasks
- Profile

3.4 Core Features Available

3.4.1 Health Summary (/user/health-summary)

The Health Summary page provides an overview of the user's submitted data. This may include trends, averages, or visual charts that help users better understand their health over time.

3.4.2 Form Management

Browsing Available Forms (/user/form-select)

Users can view a list of available forms that are approved and ready for submission. Each form is designed to collect specific types of health data.

Completing Health Forms (/user/forms)

Users can fill out forms by entering the required information into the provided fields. Validation rules ensure that the data entered is complete and in the correct format before submission.

Viewing Filled Forms

After submitting a form, users can revisit their previous submissions to review the data they have entered.

3.4.3 Progress Tracking (/user/my-progress)

The Progress Tracking feature allows users to monitor changes in their health data over time. This may include visual representations such as charts or summaries that highlight trends and patterns.

3.4.4 Task Management (/user/todo)

The Task Management section helps users keep track of any assigned or recommended actions. This may include reminders to complete forms or follow specific health-related activities.

3.4.5 User Profile (/user/profile)

The Profile section allows users to view and update their personal information. Users can also manage account settings such as password changes or security preferences.

3.5 Permissions and Limitations

What data can Users view?

Users can view:

- Their own submitted health data
- Personal summaries and progress reports
- Their account and profile information

What data can Users modify?

Users can:

- Submit new forms
- Update their profile information
- Modify certain entries before submission

Privacy and Confidentiality

User data is kept private and is not shared with other users. Any use of data for research or analysis is anonymized to protect individual identities. The system ensures that personal information is handled securely at all times.

3.6 Step-by-Step Tutorials**Completing a Health Form**

1. Navigate to the Forms section
2. Select an available form
3. Enter the required information in each field
4. Review your responses
5. Submit the form

Tracking Your Health Progress

1. Go to the Progress Tracking page
2. Select the desired metric or time range
3. View charts or summaries displaying your data over time

Managing Your Profile

1. Navigate to the Profile section
2. Update your personal information as needed
3. Save changes

Viewing Your Health Summary

1. Go to the Health Summary page
2. Review the displayed data and visualizations
3. Use filters to adjust the view

4. HCP Role (Healthcare Provider)

4.1 Overview and Purpose

Who is an HCP?

A Healthcare Provider (HCP) is a verified user within the Health Data Bank System who has the ability to review and interpret patient health data. This role is intended for individuals with a healthcare-related background, such as doctors, nurses, or support staff, depending on the context in which the system is used.

What is the role of an HCP in the system?

The primary role of an HCP is to support users by reviewing their submitted health data and, where appropriate, providing feedback or guidance. HCPs act as a bridge between raw data and meaningful interpretation, helping users better understand their health information.

What can an HCP do?

Healthcare Providers can:

- View patient health records (when access is permitted)
- Review submitted health data and identify trends
- Add clinical feedback based on patient data
- Generate reports related to patient activity
- Manage their own provider profile

What can an HCP NOT do?

Healthcare Providers cannot:

- Access data for users without proper authorization or consent
- Modify original patient-submitted data directly
- Access anonymized research datasets beyond their scope
- Perform administrative actions such as managing system roles or settings

These limitations help ensure that HCPs focus only on their intended responsibilities while maintaining data integrity.

4.2 Getting Started

Account Creation and Registration as HCP

Healthcare Providers must register for an account and may be required to undergo additional verification before being granted HCP-level access. This ensures that only qualified individuals can access patient-related data.

Provider Profile Setup

After registration, HCPs should complete their profile by adding relevant details such as their name, role, and any applicable credentials. A complete profile helps establish trust and ensures accurate identification within the system.

Security Configuration

HCPs are encouraged to enable security features such as Two-Factor Authentication (2FA) to protect their accounts. Given the sensitivity of patient data, maintaining strong account security is especially important for this role.

4.3 HCP Dashboard

Accessing the Provider Dashboard (/provider/dashboard)

Once logged in, HCPs are directed to the provider dashboard. This serves as the central hub for accessing patient data and managing provider-related tasks.

Dashboard Features and Statistics

The dashboard may display:

- A list of assigned or accessible patients
- Recent patient activity or updates
- Quick access to patient records and reports

Key Metrics and Overview

HCPs may also see summary information such as:

- Number of patients under their care
- Recent submissions or updates from patients
- High-level health trends

These elements provide a quick overview of current activity and help prioritize tasks.

4.4 Core Features Available

4.4.1 Patient Management

Viewing Patient List (/provider/patients)

HCPs can access a list of patients for whom they have permission to view data. This list serves as the starting point for reviewing patient records

Accessing Patient Records (/provider/patient/{id})

By selecting a patient, HCPs can view detailed health records, including submitted forms and associated data entries.

Patient Health Entry Management

While HCPs cannot alter original submissions, they can review entries and use them to inform their clinical notes or feedback.

4.4.2 Patient Health Records**Reviewing Patient Health Data**

HCPs can examine patient-submitted data to identify patterns, changes, or areas of concern. This information can support better decision-making.

Updating Patient Information

In some cases, HCPs may be allowed to update specific non-critical patient information or add supplementary data, depending on system permissions.

Adding Clinical Notes

HCPs can record observations, feedback, or recommendations related to a patient's health data. These notes provide additional context and can be referenced later.

4.4.3 Provider Reports (/provider/reports)**Generating Reports for Patients**

HCPs can generate reports based on patient data to summarize health trends or provide structured insights.

Exporting Patient Data (where applicable)

Where permitted, HCPs may export patient-related data for offline review or documentation purposes. Export options are typically limited to ensure data privacy.

4.4.4 Provider Profile (/provider/profile)**Managing Provider Information**

HCPs can view and update their personal and professional information within the system.

Updating Credentials

Providers may update relevant credentials or account settings as needed to maintain accurate records.

4.5 Permissions and Limitations

HIPAA Compliance and Privacy

The system is designed with privacy and data protection in mind. HCPs are expected to handle all patient data responsibly and in accordance with applicable privacy standards. While the system incorporates security measures, users must also follow proper practices when accessing and using data.

Data Access Restrictions

HCPs can only access data for patients they are authorized to view. Unauthorized access to other patient data is strictly restricted.

Patient Consent Requirements

Access to patient data may depend on user consent. HCPs should ensure that appropriate permissions are in place before reviewing or interacting with patient information.

What data HCPs can READ

HCPs can read:

- Patient-submitted health data
- Historical health entries
- Relevant summaries and reports

What data HCPs can UPDATE

HCPs can:

- Add clinical notes or feedback
- Update limited profile or non-critical patient information (if allowed)

They cannot modify original health submissions made by patients.

4.6 Best Practices

Patient Data Handling

HCPs should always treat patient data as confidential and avoid sharing it outside the system unless explicitly authorized.

Documentation Standards

Clinical notes should be clear, concise, and relevant. Proper documentation ensures that information remains useful for future reference.

Communication with Patients

When providing feedback, HCPs should ensure that their communication is clear and understandable, especially for users without a medical background.

Security Protocols

HCPs should:

- Use strong passwords
- Enable Two-Factor Authentication
- Log out after using shared devices

Following these practices helps maintain the integrity and security of the system.

5. Researcher Role

5.1 Overview and Purpose

Who is a Researcher?

A Researcher is a verified user who uses the Health Data Bank System to study health trends across groups of individuals. This role is typically assigned to users affiliated with academic institutions, healthcare organizations, or research bodies.

What is the role of a Researcher in the system?

The primary role of a Researcher is to analyze anonymized and aggregated data in order to identify patterns, trends, or insights that may contribute to broader health research. Researchers do not interact with individual users directly but instead work with grouped data that protects user identities.

What can a Researcher do?

Researchers can:

- Access anonymized and aggregated datasets (when authorized)
- Generate reports based on selected filters and criteria
- Create and manage research-related projects
- Export data for further analysis
- Document findings and maintain research records

What can a Researcher NOT do?

Researchers cannot:

- Access personally identifiable user data
- View or interact with individual user accounts
- Modify raw data submitted by users
- Perform administrative actions such as managing accounts or system settings

These limitations ensure that research activities remain ethical and privacy-focused.

5.2 Getting Started**Account Creation and Registration as Researcher**

Researchers must register for an account and may be required to provide additional verification details. Access to researcher features is typically granted after approval by an administrator or relevant authority.

Research Profile Setup

After registration, researchers should complete their profile by including relevant information such as their research interests, role, and institutional affiliation. This helps establish credibility and ensures proper oversight.

Institutional Affiliation Requirements

Researchers may be required to provide proof of affiliation with a recognized institution (such as a university or healthcare organization). This requirement helps ensure that data is accessed only by legitimate and accountable individuals.

IRB (Institutional Review Board) Compliance

In some cases, researchers must confirm that their work complies with ethical guidelines set by an Institutional Review Board (IRB) or equivalent body. This may involve obtaining approval for studies involving human data, even if the data is anonymized.

5.3 Researcher Dashboard

Accessing the Researcher Dashboard

Once logged in, researchers are directed to their dashboard, which serves as the main interface for managing research activities.

Dashboard Overview and Features

The dashboard typically includes:

- Access to reporting tools
- Overview of active research projects
- Quick access to data filters and export options
- Notifications or updates related to data access

Research Project Management

Researchers can use the dashboard to organize their work into projects. This may include creating new studies, managing datasets, and tracking progress over time.

5.4 Core Features Available

5.4.1 Data Access and Reporting (/api/researcher/dashboard, access restrictions enforced)

Requesting Data Access

Researchers may need to request access to specific datasets or apply filters based on criteria such as demographics or time ranges. Access is granted only if the request meets system requirements and privacy thresholds.

Viewing Authorized Data

Once approved, researchers can view aggregated data that represents groups of users rather than individuals.

Understanding Data Restrictions

All data access is subject to strict restrictions. For example, datasets must meet a minimum group size to prevent identification of individuals.

De-identified Data

All data available to researchers is de-identified. This means that personal identifiers such as names or contact details are removed or obscured before access is granted.

5.4.2 Research Projects

Creating Research Proposals

Researchers can define the scope of their studies by outlining objectives, selecting relevant data filters, and specifying metrics to analyze.

Managing Active Studies

Ongoing research projects can be updated and refined as needed. Researchers can adjust parameters or expand their analysis based on available data.

Tracking Research Progress

The system may provide tools to monitor progress, such as tracking completed reports or saved datasets.

5.4.3 Data Export and Analysis

Exporting Research Data

Researchers can export aggregated data for further analysis outside the system, typically in formats such as CSV.

Data Format Options

Exported data is structured in a way that supports analysis using common tools such as spreadsheet software or statistical programs.

Compliance with Data Usage Agreements

All exported data must be used in accordance with system policies and any applicable data use agreements. Misuse of data is strictly prohibited.

5.4.4 Reporting and Documentation

Research Reports

Researchers can generate reports summarizing their findings based on selected datasets. These reports may include statistical summaries or trends.

Study Publications

While the system may not directly publish research, it supports the preparation of findings that can be used in academic or professional publications.

Compliance Documentation

Researchers may be required to maintain documentation related to data usage, approvals, and ethical compliance.

5.5 Permissions and Limitations

Data Access Authorization Process

Access to data is not automatic. Researchers must meet specific conditions before being granted access, ensuring that all usage aligns with system policies.

Non-Researcher Users Cannot Access Researcher Features

Only users with the Researcher role can access research tools. Other roles are restricted from these features.

Ethical Research Standards

Researchers are expected to follow ethical guidelines when using system data. This includes respecting user privacy and avoiding attempts to re-identify individuals.

Institutional Requirements

Researchers may need to comply with requirements set by their affiliated institution, including approvals and reporting obligations.

Data Confidentiality and Protection

All data accessed must be handled securely. Researchers are responsible for ensuring that exported data is stored and used appropriately.

5.6 Compliance and Ethics

IRB Approval Requirements

Where applicable, researchers must obtain approval from an Institutional Review Board (IRB) or similar body before conducting studies involving human data.

Data Use Agreements

Researchers may be required to agree to specific terms outlining how data can be used, shared, and stored.

Informed Consent

Although data is anonymized, the system assumes that users have consented to their data being used for research purposes in accordance with system policies.

Ethical Research Conduct

Researchers must act responsibly and avoid any actions that could compromise user privacy or data integrity. Ethical conduct is essential for maintaining trust in the system.

6. Admin Role (Administrator)

6.1 Overview and Purpose

Who is an Administrator?

An Administrator (Admin) is a high-level user responsible for managing and maintaining the overall operation of the Health Data Bank System. This role is typically assigned to trusted individuals who oversee system functionality, user access, and data governance.

What is the role of an Admin in the system?

The Admin's role is to ensure that the system runs smoothly, securely, and in compliance with established policies. This includes managing users, reviewing and approving system content, monitoring activity, and maintaining the integrity of stored data.

What can an Admin do?

Administrators can:

- Manage user accounts and assign roles
- Create, review, and approve form templates
- Monitor system activity through audit logs
- Review reports and ensure data quality
- Perform database maintenance tasks such as backups and recovery
- Access all areas of the system

Responsibilities and Accountability

Due to their elevated access, administrators are held to a high level of responsibility. All actions performed by admins are logged within the system to ensure transparency and accountability. Admins are expected to follow established procedures and maintain the confidentiality and integrity of all data.

6.2 Getting Started

Account Creation for Administrators

Administrator accounts are typically created by existing system administrators or during system setup. These accounts are not publicly available for registration and require proper authorization.

Admin Privileges and Access

Once an account is assigned the Admin role, it gains access to all administrative features within the system. This includes dashboards, management tools, and system configuration options.

Security Protocols for Admin Accounts

Admins must follow strict security practices, including:

- Using strong, unique passwords
- Avoiding shared accounts
- Logging out after each session, especially on shared devices

Multi-Factor Authentication Requirements

To further secure admin accounts, Multi-Factor Authentication (MFA) is strongly recommended or required. This adds an additional verification step during login, reducing the risk of unauthorized access.

6.3 Admin Dashboard

Accessing the Admin Dashboard (/admin/dashboard)

After logging in, administrators are directed to the admin dashboard, which serves as the central control panel for managing the system.

Dashboard Overview

The dashboard provides access to all major administrative features, including user management, form management, reports, and audit logs.

Key Metrics and System Health

Admins may see system-level metrics such as:

- Number of active users
- Recent system activity
- Status of forms and reports
- System performance indicators

These metrics help admins quickly assess the overall health of the system.

6.4 Core Features Available

6.4.1 User Management (/admin/users)

Creating User Accounts

Admins can create new user accounts and assign appropriate roles based on system needs.

Editing User Information

Admins can update user details such as name, email, or role.

Disabling/Removing Users

Accounts can be deactivated or removed if necessary, for example, in cases of inactivity or security concerns.

Role Assignment and Changes

Admins can assign or modify roles to control user permissions.

Account Status Management

Admins can manage account statuses, such as activating or deactivating accounts.

6.4.2 Form Template Management (/admin/forms)**Creating Form Templates**

Admins can design new form templates used to collect health data.

Editing Existing Forms

Existing templates can be updated or refined as needed.

Approving Form Templates

Forms created within the system may require admin approval before becoming available to users.

Publishing/Unpublishing Forms

Admins control whether forms are visible and accessible to users.

Form Approval Status

Each form has a status (e.g., pending, approved, rejected), which admins manage.

6.4.3 Report Review and Management (/admin/reports)**Reviewing User-Generated Reports**

Admins can review reports generated within the system to ensure they meet quality and compliance standards.

Approving Reports

Reports approval before being finalized or shared.

Monitoring Report Quality

Admins are responsible for ensuring that reports are accurate and appropriately generated.

6.4.4 Database Management (/admin/database)

Database Health Monitoring

Admins can monitor database performance and identify potential issues.

Backup and Recovery

Regular backups can be created to protect against data loss, and recovery procedures can be performed if needed.

Data Integrity Checks

Admins may perform checks to ensure that stored data remains accurate and consistent.

Migration Management

System updates involving database changes can be managed through migration tools.

6.4.5 Audit Logs (/admin/audit-log)

Viewing System Activity Logs

Admins can view detailed logs of system activity, including user actions and system events.

User Activity Tracking

Logs allow admins to track actions performed by specific users.

Compliance and Security Audits

Audit logs support compliance by providing a record of system usage and access.

Exporting Audit Reports

Admins may export audit logs for external review or documentation.

6.4.6 Admin Profile (/admin/profile)

Managing Admin Account Information

Admins can update their own account details.

Admin Settings

Additional account preferences and security settings can be managed here.

6.5 Permissions and Capabilities

Administrators have full access to system functionality, including:

- **Full Read Access (READ)** – View all data within the system
- **Full Create Access (CREATE)** – Create users, forms, and other system elements
- **Full Update Access (UPDATE)** – Modify existing data and configurations
- **Full Delete Access (DELETE)** – Remove data when necessary

System Configuration Rights

Admins can configure system settings and manage overall system behavior.

No Limitations on Core Features

Unlike other roles, administrators are not restricted in terms of core functionality. However, this access must be used responsibly.

6.6 Sensitive Operations

User Deletion Procedures

Deleting user accounts should be done carefully, ensuring that any necessary data is preserved or archived beforehand.

Data Purging and Archival

Admins may remove outdated or unnecessary data, but must follow proper procedures to avoid accidental data loss.

System Backups

Regular backups should be performed to ensure data can be restored in case of system failure.

Security Incident Response

Admins are responsible for responding to security incidents, such as unauthorized access attempts or data breaches.

Compliance Reporting

Admins may be required to generate reports demonstrating that the system meets security and privacy standards.

6.7 Best Practices for Admins

Principle of Least Privilege

Even with full access, admins should only perform actions that are necessary for their role.

Regular Security Audits

Routine checks should be conducted to ensure that the system remains secure and compliant.

Backup and Disaster Recovery

Admins should maintain regular backups and test recovery procedures to ensure readiness in case of failure.

Change Management Procedures

Any major system changes should be planned, documented, and tested before implementation.

Documentation Requirements

Admins should keep clear records of system changes, user management actions, and any issues encountered.

7. Role Comparison Matrix

7.1 Feature Availability by Role

The table below provides a comparison of key system features and their availability across the four main roles: User, Healthcare Provider (HCP), Researcher, and Administrator.

FEATURE	USER	HCP	RESEARCHER	ADMIN
Submit Health Forms	✓	✗	✗	✗
View Health Data	✓	✓	✗	✓
View Patient Data	✗	✓	✗	✓
Add Clinical Notes	✗	✓	✗	✗

Access Aggregated Data	✗	✗	✗	✗
Generate Reports	✓	✓	✗	✓
Export Data	✓	✓	✗	✓
Manage Users	✗	✗	✗	✓
Manage Form Templates	✗	✗	✗	✓
View Audit Logs	✗	✗	✗	✓
System Configuration	✗	✗	✗	✓

This table highlights how functionality is distributed across roles, ensuring that each user type only has access to the features necessary for their responsibilities.

7.2 Permission Matrix

The following table outlines the general permission levels (READ, CREATE, UPDATE, DELETE) for each role within the system.

Permission Type	User	HCP	Researcher	Admin
READ	Own data only	Assigned patients	Aggregated data only	Full access
CREATE	Form submissions	Clinical notes	Research reports	Full access
UPDATE	Profile only	Notes (limited)	Research configs	Full access
DELETE	✗	✗	✗	Full access

Data Access Restrictions by Role

- Users can only access and manage their own data.
- HCPs can access patient data only when authorized and cannot modify original submissions.
- Researchers can only access anonymized and aggregated data that meets system privacy thresholds.
- Admins have full access to all data but are expected to use this access responsibly and in accordance with system policies.

This structure ensures that sensitive information is protected while still allowing each role to perform its required tasks.

7.3 Dashboard Access Summary

Each role in the system is assigned a specific dashboard that provides access to relevant features.

Role	Dashboard URL	Key Features Available
User	/user/dashboard	Health summary, forms, progress tracking, tasks, profile
HCP	/provider/dashboard	Patient list, patient records, notes, reports
Researcher	/researcher/dashboard	Data access, report generation, research projects
Admin	/admin/dashboard	User management, forms, reports, audit logs, system controls

Each dashboard is customized to match the needs of the role, ensuring a focused and efficient user experience.

Dashboard Features by Role

- User Dashboard: Focused on personal data entry and tracking
- HCP Dashboard: Focused on patient data review and feedback
- Researcher Dashboard: Focused on data analysis and reporting
- Admin Dashboard: Focused on system management and oversight

This separation of dashboards helps maintain clarity while reinforcing the role-based structure of the system.

8. Common Workflows and Scenarios

This section outlines typical workflows within the Health Data Bank System. These scenarios demonstrate how different roles interact with the system to complete common tasks.

Scenario 1: A User (Patient) Filing a Health Report

Step-by-Step Process for Completing a Health Form

1. Log in to the system using your account credentials
2. Navigate to the Forms section (e.g., /user/form-select)
3. Browse the list of available forms
4. Select a form to complete
5. Enter the required information into each field
6. Review all entries to ensure accuracy
7. Submit the form

Once submitted, the system stores the data and makes it available for future reference.

Reviewing Submissions

1. Navigate to the section where past submissions are stored
2. Select a previously completed form
3. Review the submitted data

Users can revisit their submissions at any time to check past entries.

Tracking Health Progress

1. Go to the Progress Tracking page (/user/my-progress)
2. Select a metric or time range (if applicable)
3. View charts or summaries showing changes over time

This allows users to monitor trends and better understand their health data.

Scenario 2: An HCP (Healthcare Provider) Reviewing Patient Records**Finding a patient in the system**

1. Log in as an HCP
2. Navigate to the Patient List (/provider/patients)
3. Search or browse for the desired patient

Accessing Patient Health Data

1. Select a patient from the list
2. Open their profile or record page (/provider/patient/{id})
3. Review submitted forms and health entries

Adding Clinical Notes

1. Navigate to the appropriate section within the patient record
2. Enter observations, feedback, or recommendations
3. Save the notes

These notes provide additional context and support patient care.

Generating a Patient Report

1. Navigate to the Reports section (/provider/reports)
2. Select the patient and relevant criteria
3. Generate the report
4. Review the output and export if needed

Scenario 3: A Researcher Accessing Data for a Study

Submitting Data Access Requests

1. Log in as a Researcher
2. Navigate to the data access or reporting section
3. Define the required filters (e.g., date range, demographics)
4. Submit the request for data access

Understanding IRB Requirements

Before accessing data, researchers should ensure that:

- Their study has received any required ethical approval
- Their request aligns with institutional and system guidelines

Accessing Approved Datasets

1. Once the request is approved, access the dataset through the dashboard
2. Review aggregated and anonymized data

Exporting Data for Analysis

1. Select the dataset or report
2. Choose an export option (e.g., CSV)
3. Download the file for external analysis

Researchers must ensure that exported data is handled securely and used appropriately. Only datasets that meet privacy thresholds will be available.

Scenario 4: An Admin Managing User Accounts and System

Creating New User Accounts with Appropriate Roles

1. Log in as an Admin
2. Navigate to User Management (/admin/users)
3. Create a new account
4. Assign the appropriate role (User, HCP, Researcher, or Admin)
5. Save the account

Approving Form Templates

1. Navigate to Form Management (/admin/forms)
2. Review submitted or pending templates
3. Approve or reject based on system requirements
4. Publish approved forms

Reviewing Audit Logs for Compliance

1. Navigate to the Audit Log section (/admin/audit-log)
2. Filter logs based on criteria (e.g., user, event type, date)
3. Review activity for unusual or unauthorized actions

Managing Database Backups

1. Access the database management section (/admin/database)
2. Initiate a system backup
3. Verify that the backup is completed successfully
4. Store backup files securely

Regular backups help ensure that data can be recovered in case of system issues.

9. Security and Privacy

Protecting user data is a central priority in the Health Data Bank System. Given the sensitive nature of health-related information, the system incorporates multiple layers of security to ensure that data is handled safely and responsibly. This section outlines the key security measures and privacy considerations built into the system.

9.1 Role-Based Authentication

The system uses Role-Based Authentication to control access to features and data. When a user logs in, their role determines what they are allowed to view and perform within the system.

This ensures that:

- Users can only access their own data
- Healthcare Providers can access patient data only when authorized
- Researchers can only view anonymized, aggregated datasets
- Administrators can manage system operations

By enforcing role-based access at all times, the system minimizes the risk of unauthorized data exposure.

9.2 Two-Factor Authentication (2FA)

Two-Factor Authentication (2FA) adds an additional layer of protection during login. In addition to a password, users may be required to verify their identity using a secondary method, such as a one-time code.

This significantly reduces the risk of unauthorized access, especially in cases where passwords may be compromised. Users are encouraged, and in some cases required, to enable 2FA for their accounts.

9.3 Session Management and Timeout

Once a user logs in, the system creates a session that allows them to remain authenticated while navigating the platform. To maintain security:

- Sessions automatically expire after a period of inactivity
- Users must log in again after a timeout
- Logging out properly ends the session

These measures help protect user accounts, particularly when the system is accessed from shared or public devices.

9.4 Password Requirements and Updates

Users are required to create strong passwords when registering for an account. Password requirements may include:

- A minimum length
- A combination of letters, numbers, and special characters

Users are encouraged to update their passwords regularly and avoid reusing passwords across different platforms. If a user suspects that their account has been compromised, they should change their password immediately.

9.5 Data Encryption Standards

The system uses encryption to protect data both in transit and at rest:

- Data in transit is secured using standard web encryption protocols (such as HTTPS)
- Sensitive data at rest is stored in a protected format to prevent unauthorized access

Encryption ensures that even if data is intercepted or accessed improperly, it cannot be easily read or misused.

9.6 HIPAA Compliance for HCP and Researcher Roles

The system is designed with privacy and data protection principles similar to those found in healthcare standards such as HIPAA (Health Insurance Portability and Accountability Act). While the system may not be formally certified, it follows best practices related to:

- Limiting access to sensitive data
- Protecting patient confidentiality
- Ensuring accountability through logging and monitoring

Healthcare Providers and Researchers are expected to handle data in a way that aligns with these principles and any applicable institutional or legal requirements.

9.7 Audit Trail and Logging

All significant system activities are recorded in audit logs. These logs track actions such as:

- User logins and logouts
- Data access and modifications
- Administrative actions

Audit logs provide transparency and allow administrators to monitor system usage, detect unusual activity, and support compliance requirements.

9.8 Account Lockout Procedures

To prevent unauthorized access, the system may temporarily lock an account after multiple failed login attempts. This helps protect against brute-force attacks.

Users who are locked out may:

- Wait for the lockout period to expire
- Use password recovery options
- Contact system administrators for assistance

9.9 Security Best Practices for Each Role

All users share responsibility for maintaining system security. The following best practices are recommended:

- Use strong and unique passwords
- Enable Two-Factor Authentication (2FA) whenever possible
- Log out after each session, especially on shared devices
- Avoid sharing account credentials with others
- Be cautious when accessing the system on public networks

Additionally:

- Healthcare Providers and Researchers should ensure that any exported data is stored securely
- Administrators should regularly review audit logs and perform system checks

Following these practices helps maintain a secure and trustworthy system for all users.

10. Troubleshooting and FAQs

This section provides guidance on common issues that users may encounter while using the Health Data Bank System, along with answers to frequently asked questions.

- **10.1 Unable to Access Your Dashboard**

If you are unable to access your dashboard after logging in, the issue is often related to role assignment or session status.

Role Verification Steps

- Ensure that your account has been assigned the correct role (User, HCP, Researcher, or Admin)
- Try logging out and logging back in to refresh your session
- If the issue persists, contact an administrator to confirm your role and access permissions

Session Timeout Solutions

- If you have been inactive for a period of time, your session may have expired
- Simply log in again to regain access
- Avoid leaving the system idle for extended periods, especially on secure pages

10.2 Permission Denied Errors

A “Permission Denied” message typically means that you are trying to access a feature or page that is not available to your role.

Understanding Access Restrictions

- Each role has specific permissions that limit what actions can be performed
- For example, a User cannot access admin tools, and a Researcher cannot view personal user data
- These restrictions are enforced automatically by the system

Requesting Elevated Permissions

- If you believe you require access to a feature, contact an administrator
- Provide a clear explanation of why access is needed
- Access may be granted if it aligns with your role and responsibilities

10.3 Form Submission Issues

If you are experiencing issues when submitting a form, consider the following:

- Ensure all required fields are completed
- Check that the data entered follows the specified format (e.g., valid email, numeric values)
- Review any error messages displayed on the form
- Refresh the page and try again if the issue persists

If problems continue, it may be due to a system error or validation issue. In this case, contacting support or an administrator is recommended.

10.4 Frequently Asked Questions

What role do I need for specific features?

- User: For submitting and tracking personal health data
- HCP: For reviewing patient data and adding clinical notes
- Researcher: For accessing aggregated and anonymized data
- Admin: For managing the system and user accounts

How do I change my role?

Roles cannot typically be changed directly by users. To request a role change:

1. Contact an administrator
2. Provide any required documentation or justification
3. Wait for approval

How do I report a security issue?

If you notice any suspicious activity or potential security concerns:

1. Report the issue to an administrator immediately
2. Provide details such as what happened and when
3. Avoid sharing sensitive information through unsecured channels

Prompt reporting helps maintain system security and protect user data.

How do I access data as a Researcher?

To access data as a Researcher:

1. Ensure your account has been assigned the Researcher role
2. Submit a data access request through the system
3. Wait for approval based on system policies and requirements
4. Access approved datasets through the researcher dashboard

All data provided will be anonymized and subject to system restrictions.

11. System Integration and API Access

The Health Data Bank System provides API access to support integration with external tools and services. This allows authorized users and systems to interact with data programmatically, while still maintaining strict security and access control.

API usage is governed by authentication mechanisms and role-based permissions to ensure that all requests are properly authorized

11.1 API Token Permissions

Available API Scopes: read, create, update, delete

API tokens are assigned specific permission scopes that define what actions can be performed. These scopes include:

- read – Allows retrieval of data (e.g., viewing records or reports)
- create – Allows submission of new data (e.g., form submissions)
- update – Allows modification of existing data (where permitted)
- delete – Allows removal of data (typically restricted to administrators)

Each token is limited to the scopes assigned to it, ensuring that access remains controlled and appropriate.

Token Generation and Management

Authorized users can generate API tokens through their account settings (if enabled for their role). When creating a token:

1. The user selects the required permission scopes
2. The system generates a unique token
3. The token is displayed once and should be stored securely

Users can manage their tokens by:

- Revoking unused or compromised tokens
- Regenerating tokens when necessary

Proper token management is important to prevent unauthorized access.

All API requests must be authenticated using a valid API token. Typically, this is done by including the token in the request header.

Example:

Authorization: Bearer <your_api_token>

Requests without valid authentication will be rejected. This ensures that only authorized users or systems can access the API.

11.2 Role-Based API Access**Which API Endpoints Are Available to Each Role**

Access to API endpoints is determined by the user's role:

- User Role:
 - Submit health data
 - Retrieve personal data
 - Limited to endpoints related to their own account
- HCP Role:
 - Access patient-related endpoints (where authorized)
 - Add clinical notes
 - Generate patient reports
- Researcher Role:
 - Access aggregated data endpoints
 - Generate and export research reports
 - Restricted to anonymized datasets
- Admin Role:
 - Full access to all API endpoints
 - Manage users, forms, reports, and system data

All endpoints enforce role-based restrictions to prevent unauthorized access.

Request/Response Examples

Below are simplified examples of how API requests and responses may look:

Example 1: Retrieve User Data (User Role)

Request:

GET /api/user/health-summary

Authorization: Bearer <token>

Response:

```
{
  "status": "success",
  "data": {
    "summary": {
      "entries": 10,
      "average_metric": 75
    }
  }
}
```

Example 2: Generate Aggregated Report (Researcher Role)

Request:

POST /api/researcher/reports/aggregated

Authorization: Bearer <token>

Response:

```
{
  "status": "success",
  "data": {
    "cohort_size": 50,
    "average_value": 68.4
  }
}
```

Example 3: Access Audit Logs (Admin Role)**Request:**

GET /api/admin/audits

Authorization: Bearer <token>

Response:

```
{
  "status": "success",
  "data": [
    {
      "event": "login_success",
      "user_id": "123",
      "timestamp": "2026-04-15T10:30:00"
    }
  ]
}
```

These examples demonstrate how API access is structured and how responses are returned. Actual endpoints and data formats may vary depending on system configuration.

This section provides an overview of how the system supports integration while maintaining strict security and role-based access control.

12. Support and Additional Resources

This section provides information on how users can get assistance, access training materials, and provide feedback to improve the system.

12.1 Getting Help

Contact Information

Users who require assistance can contact system support through the appropriate communication channels provided by the organization or development team. This may include email, internal messaging systems, or designated support contacts.

Support Ticket Submission

For technical issues or system-related problems, users are encouraged to submit a support ticket. When submitting a ticket:

- Provide a clear description of the issue
- Include any relevant screenshots or error messages
- Specify the steps taken before the issue occurred

This helps the support team identify and resolve the issue more efficiently.

FAQ Resources

Users can refer to the Frequently Asked Questions (FAQ) section for quick answers to common problems. This is often the fastest way to resolve minor issues without needing direct support.

13. Glossary of Terms

This section defines key terms used throughout the guide.

- **Account Type:** The classification assigned to a user (e.g., User, HCP, Researcher, Admin) that determines their permissions.
- **HIPAA:** A set of healthcare data privacy and security standards (primarily used in the United States) that guide the protection of sensitive patient information.
- **IRB (Institutional Review Board):** A committee that reviews and approves research involving human participants to ensure ethical standards are met.
- **De-identified Data:** Data that has had personal identifiers removed so that individuals cannot be identified.
- **Role-Based Access Control (RBAC):** A system that restricts access to features and data based on user roles.
- **API Token:** A secure key used to authenticate and authorize API requests.
- **Health Entry:** A single record of health-related data submitted by a user.
- **Form Template:** A predefined structure used to collect specific types of data from users.
- **Audit Log:** A record of system activity, including user actions and system events, used for monitoring and accountability.
- **Two-Factor Authentication (2FA):** A security process that requires two forms of verification before granting access to an account.

14. Appendices

The appendices provide additional supporting materials and reference documents related to the system.

A. Role Assignment Request Form

A standardized form used to request a change or assignment of user roles. This may require approval from an administrator and supporting documentation.

B. Data Access Agreement Template (for Researchers)

A document outlining the terms and conditions for accessing and using system data. Researchers must agree to these terms before accessing datasets.

C. System Architecture Overview

A high-level description or diagram of how the system is structured, including major components such as the frontend, backend, database, and APIs.

D. Database Schema Overview

An outline of the database structure, including key tables, relationships, and data flow within the system.

E. Middleware and Security Measures

Details on how middleware is used to enforce authentication, authorization, and request handling within the system.

F. Emergency Contact Procedures

Guidelines for responding to urgent issues, such as system outages or security incidents. This includes who to contact and what steps to follow.